

Checkpoint Minggu 9 — Kelompok 12 Kelas B

- Skenario 10: IoT Protocol Guardian (MQTT replay & publish tanpa izin).
- Thevan Erlangga (Lead) | Muhamad Akhdan Ramadhan (Red) | Fachri Abyasa Tarid (Blue).
- Subnet lab terisolasi 192.168.12.0/24: attacker .100, target .5, monitoring .200.

1 Konteks proyek IoT: penyemprotan sapi otomatis

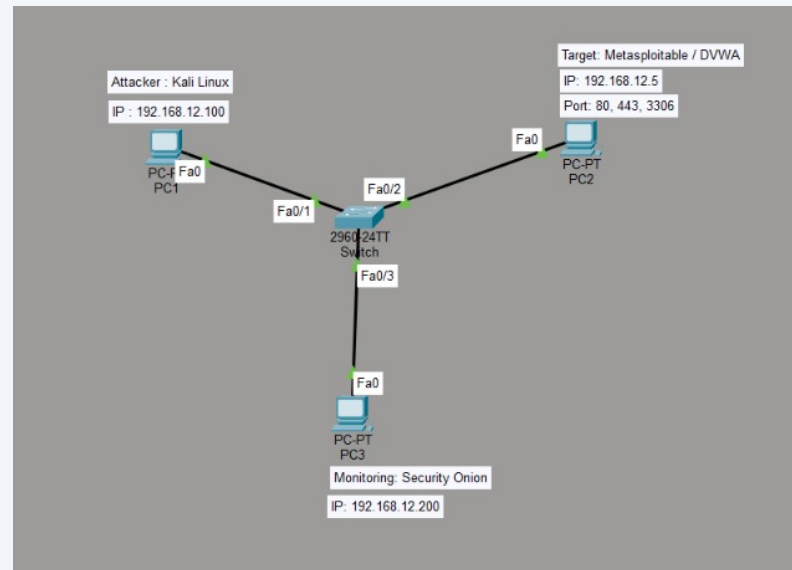
- Sensor DS18B20 dibaca ESP32, dikirim ke Firebase Realtime Database via HTTP.
- Dashboard web Firebase Hosting pantau suhu; saat threshold tersentuh, perintah semprot ditulis ke database.
- ESP32 baca perintah, teruskan ke relay lalu ke solenoid valve. Semprotan nyala.
- Celahnya jelas: siapa bisa menyuntik suhu palsu atau perintah palsu bisa menyalakan semprotan seenaknya.

2 Deklarasi tech stack: asli vs replika

- OS: Firebase managed (tanpa OS) direplikasi jadi Arch Linux di Target Node.
- Database: Firebase Realtime Database; replika menyusul Fase 2. Data asli DILARANG masuk lab, semua dummy.
- Sensor: ESP32+DS18B20 via HTTP direplikasi jadi publish MQTT (port 1883 siap) + HTTP port 80.
- Aktuator: RTDB → ESP32 → relay → solenoid direplikasi jadi service simulasi Fase 2.

3 Arsitektur simulasi (hasil Minggu 4, dipakai ulang)

- Attacker .100 (LabVM, nmap + ping) → Target .5 (Arch, direplikasi backend sapi) → dipantau Onion .200 (Sguil).
- Serangan HANYA ke .5. Dilarang ke jaringan kampus, Wi-Fi publik, atau kelompok lain.



Topologi Attacker - Target - Monitoring, segmen 192.168.12.0/24.

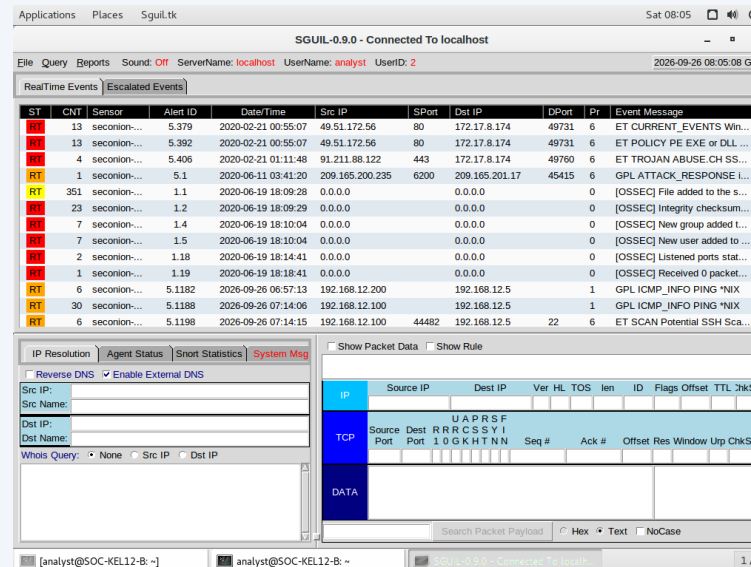
4 Progres hardening: 9 kontrol, 3 kategori

- Akses: root login SSH dimatikan, SSH khusus sec_admin, MaxAuthTries 3 (bukti: sshd before/after).
- Service: iptables DROP + whitelist direplikasi ulang dan dibuat persisten; akun analyst dikunci; port asing tertutup (bukti: nmap).
- Data: SSH LogLevel VERBOSE, journal persistent, banner peringatan.
- Temuan jujur: aturan Fase 1 sempat hilang (tabel kosong) — sekarang disimpan + service enabled. Patch offline menunggu internet.

5 Live demo: monitoring jalan

- Ping .100 ke .5: 0% loss, tercatat GPL ICMP_INFO PING di Sguil.
- Scan nmap memicu baris ET SCAN; brute-force nanti terlihat di journal VERBOSE + Sguil.

- Demo di layar: ping ulang dari attacker, tunjukkan baris barunya muncul di Sguil.



Sguil merekam ping dan SSH scan dari .100 ke .5 (contoh sesi sebelumnya).

6 Attack plan Fase 2 + kendala

- Skenario 1 recon: nmap -sS -sV -O (sudah ada, sudah jalan).
- Skenario 2 brute-force SSH: Hydra bila ada internet, fallback Nmap NSE ssh-brute (offline).
- Skenario 3 MQTT replay/publish palsu: mosquitto_pub/MQTT Explorer, fallback HTTP POST suhu palsu.
- Tiap skenario tutup loop 5 tahap: serang, deteksi, analisis, respons, verifikasi ulang.
- Kendala: segmen tanpa internet (no pacman/fail2ban/Mosquitto), RAM host pas-pasan buat Onion 4 GB.